

# KYRA AI Guardrail

---

엔터프라이즈 AI 보안 및 거버넌스 플랫폼

# 목차 (Table of Contents)

I. Executive Summary

II. Features & Architecture

III. Agentic AI 보안

IV. 구축 방법론

# Executive Summary

---

## 시장 현황

- Fortune 500 기업의 65% 생성형 AI 파일럿 진행 중 (McKinsey 2024)
- 데이터 유출 사고 평균 피해액: \$4.88M (IBM)
- OWASP LLM Top 10: 프롬프트 인젝션이 1위 위협

## 핵심 과제

- AI 도입 기업의 55% 데이터 프라이버시를 최대 리스크로 선정
- 보안 없는 AI는 최대의 리스크

# KYRA AI Guardrail 솔루션

---

## 통합 플랫폼

-  프롬프트 인젝션 방어 (Jailbreak Prevention)
-  데이터 유출 방지 (DLP - Data Loss Prevention)
-  컴플라이언스 자동화 (Compliance Automation)
-  고급 RAG 시스템 (Advanced RAG)
-  Multi-Tenancy 지원 (Enterprise Isolation)

# AI Agent 사례: 무역기업

통관 & 컴플라이언스 자동화

# Trade AI Agent Use Case

## 무역기업: 통관 & 컴플라이언스 자동화

| 항목 | 설명                            |
|----|-------------------------------|
| 산업 | 무역/수출입, 국제거래 기업               |
| 배경 | 통관 지연, 컴플라이언스 담당 부하, 문서 처리 오류 |
| 배포 | 클라우드 (AWS/On-Prem 하이브리드)      |
| 기간 | POC 4주 → 전사 적용 3개월            |

# Trade Agents (에이전트 역할)

---

## 주요 에이전트

1. **통관 문서 분석** (Level 3)
  - HS코드, 원산지, 세관신고 추출
2. **수출규제 준수** (Level 4)
  - EAR/ITAR 규제 자동 점검
3. **거래선 매칭** (Level 3)
  - 공급자/구매자 신용도 분석
4. **ESG 컴플라이언스** (Level 2)
  - 강제노동, 환경규제 체크

# Agentic AI 보안 아키텍처

RBAC & ABAC 듀얼 제어



# RBAC 기반 역할 제어

---

## Role-Based Access Control

### 에이전트 요청 처리 흐름

1. ◆ **요청 수신**: Agent가 문서 읽기, 도구 호출
2. ◆ **역할 추출**: Gateway에서 JWT 토큰으로 역할 확인
3. ◆ **정책 평가**: OPA (Open Policy Agent)에서 role:resource 권한 검사
4. ◆ **의사결정**: 허용(✓) / 거부(✗) + 감사로그

# RBAC 역할 & 권한 매트릭스

| 역할         | 공개 문서 | 내부 문서 | 기밀 문서 | Tool 호출 |
|------------|-------|-------|-------|---------|
| Admin      | ✓     | ✓     | ✓     | 전체      |
| Manager    | ✓     | ✓     | ✓     | 제한      |
| Power User | ✓     | ✓     | X     | 지정      |
| User       | ✓     | ✓     | X     | 읽기      |
| Viewer     | ✓     | X     | X     | 없음      |

## 성과 지표

<5ms

정책 적용 지연

100%

실시간 역할 반영

0

권한 위반 (감시)

# ABAC 기반 속성 제어

## Attribute-Based Access Control

동적 정책 평가 흐름

[Agent 요청] → [속성 추출] → [OPA ABAC 정책] → [ALLOW/DENY]

정책 속성 (Attributes)

| 속성                 | 설명      | 예시                                            |
|--------------------|---------|-----------------------------------------------|
| doc.classification | 문서 분류등급 | public   internal   confidential   restricted |
| user.role          | 사용자 역할  | admin   manager   user   viewer               |
| user.tenant_id     | 테넌트 격리  | 기업별 데이터 완전 분리                                 |
| agent.action       | 에이전트 동작 | read   write   tool_call   export             |
| context.time       | 시간대별 접근 | 옵션: 시간 기반 제한                                  |

# ABAC 관리 콘솔

## 역할 × 분류등급 권한 매트릭스

### 관리 콘솔 특징:

- ☒ Non-technical Ops 팀이 UI로 정책 관리
- ☒ 역할 × 분류등급 매트릭스로 권한 설정
- ☒ 변경사항 자동 저장 (<5ms 반영)
- ☒ 모든 접근 감시로깅

### 접근 제어 규칙 예시

- **Admin**: 모든 문서 및 권한 관리 가능
- **Manager**: Public + Internal + Confidential (Restricted 제외)

# 구축 방법론

솔루션 + 커스터마이징 병행

## 3단계 구축 로드맵

---

### Phase 1: 솔루션 기본 도입 (1-2개월)

#### Foundation 배포

- Docker Compose 배포 (33개 컨테이너)
- RBAC/ABAC 기본 정책 활성화
- RAG 시스템 연동 (Milvus + MinIO)
- 사용자 인증 (JWT, Multi-Tenancy)

## Phase 2: KITA 맞춤 커스터마이징 (3개월)

---

### KITA-Specific 구성

- 무역 도메인 데이터 학습/RAG 구성
- 민감정보(통관번호, 사업자번호, 계좌) **PII 탐지 규칙** 추가
- Agent Tool 권한 정책 설계 (무역 워크플로우 기반)
- 대시보드 위젯 커스터마이징

## Phase 3: 운영 안정화 & 이관 (1개월)

---

### Handover & 운영 준비

- 성능 튜닝 (Target: Latency <200ms, Block Rate >99.5%)
- 운영 매뉴얼 + 보안 정책서 작성
- **KT DS 운영팀 기술 이전 (상주 지원 가능)**



# 구축 타임라인 & KPI

---

## 구축 일정

- **Phase 1:** 1-2개월
  - Docker 배포 완료
  - 기본 정책 활성화
- **Phase 2:** 3개월
  - KITA 데이터 통합
  - Tool 권한 설정
- **Phase 3:** 1개월
  - 성능 튜닝
  - 팀 이관

# Secure AI. Empower Enterprise.

---

SeekersLab KYRA AI Guardrail

